

Department of Computer Science & Engineering
QUESTION BANK FOR VI SEMESTER (Term: FEB-JUNE 2026)
Penetration Testing and Secure Systems Laboratory (CSL65)
Exam Hours: 03
Credits: 0:0:1
Exam Marks: 50

- You are given browser-based remote access (Apache Guacamole) to a Kali Linux attack box placed on an isolated lab network. Three vulnerable web applications are deployed as targets on that network, each with a randomised IP address and service port. Enumerate the network to discover the three targets, then identify and exploit the vulnerabilities present in each application. Every target hosts a built-in score board that records your progress; you must solve all listed challenges within the allotted time.

Time allowed: 3 hours

Total vulnerabilities: 12 (Target 1: 6, Target 2: 3, Target 3: 3)

Deliverable: exploit each vulnerability

Vulnerability details to expect on the exam

The student is expected to enumerate each application, identify the vulnerability class, and exploit it to the stated outcome. Targets are standard, well-documented training applications; payloads/answers are not given here.

Target | - OWASP Juice Shop (6 challenges)

#

Vulnerability class (OWASP)

What the student must achieve

11

Sensitive Data Exposure (A01/A05)

Locate and access a confidential file that should not be publicly reachable (directory/static-file exposure).

2

Security Misconfiguration (A05)

Discover and reach the unauthenticated application metrics endpoint.

3

Injection - SQL (A03)

Authenticate as the administrator by injecting into the login form (authentication bypass via SQLi).

4

Broken Access Control -

IDOR (A01)

View another user's shopping basket by manipulating a direct object reference.

5

Injection - SQL (A03)

Extract the database schema using a UNION-based SQL injection in a search/query parameter.

6

Broken Access Control (AOL)

Submit a product review attributed to a different user.

Target 2 - OWASP Security Shepherd (3 modules)

Target 3 — NanoCorp Bites (3 challenges)

#

Module

Vulnerability class (OWASP)

What the student must achieve

Cross-Site

Request Forgery

CSRF (A01)

Craft a request that performs a state-changing action on behalf of a victim, defeating the module's CSRF check.

SQL Injection

Injection - SQL (A03)

Manipulate a query through unsanitised input to retrieve the protected result/key.

3

Cross Site

Scripting

Injection - XSS, reflected (A03)

Inject a script that executes in the browser to complete the reflected-XSS module.

#

Challenge key

Vulnerability class

(OWASP)

What the student must achieve

reflected

_xSS

Injection - XSS, reflected (A03)

Find a user-supplied value that is reflected into a page unescaped and execute script through it.

2

stored_xss

Injection - XSS, stored (A03)

Persist input that is later rendered to users unescaped, executing script when the page is viewed.

3

idor

Broken Access Control

- IDOR (A01)

Access another user's resource served by direct object reference with no ownership check.

Marks Distribution

Conduction and Result

Write Up

Execution

Target-1

15 Marks

10 Marks

10 Marks

Viva
Total
Target-2
7 Marks
Target-3
50 Marks